ANCHOR FINANCIALS · INFORMATION SECURITY

Information Security Policy Pack

Anchor CBS — Web-Based SACCO Core Banking / ERP Platform

Version 1.0 · Effective 11 November 2026

Classification: Internal / Confidential · Owner: Management · Approver: CEO / Board · Review: Annually

Anchor Financials — Information Security Policy Pack

System: Anchor CBS — Web-Based SACCO Core Banking / ERP Platform
Organization: Anchor Financials

Document control	
Policy ID	AF-POL-00
Version	1.0
Effective date	11 November 2026
Owner	Management
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

1. Purpose

1.1 This policy pack sets out how Anchor Financials protects the confidentiality, integrity and availability of information held and processed in Anchor CBS, and how staff, contractors and third parties must use and protect that information.

1.2 The pack is the organization's own management system for information security. It is written to be adopted, signed and operated by Anchor Financials. Anchor Financials does **not** claim ISO/IEC 27001 certification or any other certification; ISO/IEC 27001 is used only as a reference structure while the organization builds its controls.

1.3 The pack supports preparation for an INSA cybersecurity audit against the INSA Cybersecurity Audit Minimum Requirements (OF/AEAD/001). It does not itself constitute an audit opinion or certification.

2. Scope

2.1 The pack covers the Anchor CBS web application, REST API, PostgreSQL database, nginx reverse proxy, Ubuntu host, JWT authentication, SMS OTP multi-factor authentication, role-based access control and

the immutable hash-chained audit trail.

2.2 It also covers the people, processes, facilities and third parties that support those components, including the hosting provider and the AfroMessage SMS gateway.

2.3 The following are out of scope: POS terminals, electronic invoice machines, fiscal printers, card readers, ATM/switch integration, customer mobile or internet banking channels, and device firmware. Where such systems are introduced, this pack must be extended before deployment.

2.4 Physical and environmental controls operated by the hosting provider are covered by AF-POL-12 and AF-POL-06. Anchor Financials remains accountable for verifying that those controls are effective.

3. Policy framework and authority

3.1 The Board owns information security risk and approves this pack. The CEO is accountable for implementation. The CISO/Security Officer maintains the pack and reports on its performance.

3.2 This pack sits above supporting standards, procedures, checklists and records. Where a policy conflicts with a procedure, the policy prevails until the conflict is resolved by the CISO/Security Officer.

3.3 The pack is aligned with:

- The Personal Data Protection Proclamation No. 1321/2024 and applicable data protection directives;
- The Computer Crime Proclamation No. 958/2016;
- Applicable National Bank of Ethiopia (NBE) directives on microfinance/SACCO supervision, reporting, AML/CFT and cyber resilience;
- Applicable federal and regional cooperative and SACCO laws;
- INSA Cybersecurity Audit Minimum Requirements (OF/AEAD/001);
- ISO/IEC 27001 as a non-certified reference model.

3.4 The policy set is reviewed together, at least annually, so that cross-references and control expectations remain consistent.

4. Policy register

ID	Policy	Purpose	Owner	Review
AF-POL-01	Information Security Policy	Establishes security objectives, governance, roles, compliance and exceptions.	CISO/Security Officer	Annually
AF-POL-02	Access Control and Authentication Policy	Controls least privilege, RBAC, passwords, MFA, sessions, provisioning and access reviews.	CISO/Security Officer	Annually
AF-POL-03	Incident Response Plan	Defines severity, response lifecycle, notification, evidence and post-incident review.	CISO/Security Officer	Annually
AF-POL-04	Business Continuity and Backup Policy	Sets RTO/RPO, backup, restore testing and disaster recovery arrangements.	Operations Manager	Annually
AF-POL-05	Data Retention and Deletion Policy	Sets retention periods, legal holds, secure deletion, masking and data subject requests.	CISO/Security Officer	Annually
AF-POL-06	Vendor and Third-Party Policy	Controls due diligence, contracts, access, monitoring and exit for suppliers.	Operations Manager	Annually

ID	Policy	Purpose	Owner	Review
AF-POL-07	Acceptable Use Policy	Defines authorized use of systems, devices, email, internet and data.	CISO/Security Officer	Annually
AF-POL-08	Security Awareness and Training Policy	Sets onboarding, annual, phishing, secure coding and privileged-user training.	CISO/Security Officer	Annually
AF-POL-09	Risk Management Policy	Defines risk method, register, appetite, treatment, ownership and review.	CISO/Security Officer	Annually
AF-POL-10	Change Management Policy	Controls change types, approval, testing, rollback, database migration and review.	Operations Manager	Annually
AF-POL-11	Logging and Monitoring Policy	Sets logged events, immutable audit trail, NTP, retention, review and alerting.	CISO/Security Officer	Annually
AF-POL-12	Physical and Environmental Security Policy	Covers hosting facilities, access, visitors, CCTV, power, disposal and devices.	Operations Manager	Annually

5. Adoption and sign-off

5.1 By signing below, the approvers adopt this pack with effect from 11 November 2026 and authorize management to enforce it.

5.2 Staff and contractors acknowledge the pack through the onboarding process and at each annual refresh. Acknowledgement records are retained by Human Resources.

Name	Title	Signature	Date
[Name]	Chief Executive Officer (CEO)		
[Name]	CISO / Security Officer		
[Name]	Operations Manager		
[Name]	Head of Internal Audit		

6. Distribution, exceptions and review

6.1 The pack is classified Internal. It is published to all staff on the organization's document repository, with a controlled copy held by the CISO/Security Officer.

6.2 Exceptions are requested and approved under AF-POL-01 section 8. No policy exception is valid without a recorded risk acceptance and expiry date.

6.3 The pack is reviewed annually by 11 November, and earlier after a major incident, a material change to Anchor CBS, a new regulatory requirement or an audit finding that affects policy content.

6.4 The CISO/Security Officer reports annually to the Board on policy compliance, open exceptions, risk treatment and audit findings.

7. Document history

Version	Date	Author	Change
1.0	11 November 2026	CISO/Security Officer	Initial policy pack adopted.

01 — Information Security Policy

Document control	
Policy ID	AF-POL-01
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All Anchor Financials employees, directors, contractors, interns, temporary staff and third parties who access Anchor CBS or Anchor Financials information.

1. Purpose

1.1 This policy defines Anchor Financials' information security objectives, governance, responsibilities and the rules by which the organization protects information. It is the top-level policy for the pack indexed in AF-POL-00.

1.2 It establishes management commitment to protect member information, financial records and the Anchor CBS platform, and to meet Ethiopian legal, NBE and INSA expectations.

2. Objectives

2.1 Protect the confidentiality of member, KYC, financial and personnel information.

2.2 Preserve the integrity and accuracy of transactions, ledger balances, reports and the audit trail.

2.3 Maintain availability of Anchor CBS within the recovery targets in AF-POL-04.

2.4 Detect, report and respond to security incidents in accordance with AF-POL-03.

2.5 Meet applicable legal, regulatory, contractual and audit obligations.

2.6 Build security awareness and accountability across all users.

2.7 Continuously improve controls through risk assessment, audit and management review.

3. Scope

3.1 This policy applies to all information assets used to deliver Anchor CBS, including:

- the web front end, Spring Boot API, PostgreSQL database, nginx proxy and Ubuntu hosts;
- JWT credentials, SMS OTP factors, API keys and encryption keys;
- member, KYC, savings, shares, loan, accounting, reporting and audit data;
- backups, exports, reports and supporting documents in any format;

- hosting, SMS and other third-party services;
- staff devices and remote connections used to access the platform.

3.2 The boundaries and exclusions in AF-POL-00 section 2 apply.

4. Security principles

4.1 **Confidentiality.** Information is accessible only to authorized users for authorized purposes. Access is granted on least privilege and need to know.

4.2 **Integrity.** Data and systems are protected from unauthorized or accidental modification. Financial transactions are subject to maker-checker controls, and audit records are append-only and hash-chained.

4.3 **Availability.** Systems and data are available to support SACCO operations and are recoverable within approved RTO/RPO targets.

4.4 **Accountability.** Every user has a unique identity. Privileged and financial actions are attributable and logged.

4.5 **Risk-based protection.** Controls are proportionate to the sensitivity of the asset and the assessed risk under AF-POL-09.

4.6 **Privacy by design.** Personal data is collected for defined purposes, minimized, protected and retained only as required by AF-POL-05.

4.7 **Defence in depth.** Access control, authentication, logging, backup, physical security and vendor controls operate together; no single control is relied upon alone.

4.8 **Continual improvement.** Incidents, audit findings and changes feed corrective action and policy review.

5. Roles and responsibilities

Role	Responsibilities
Board	Owns information security risk; approves this pack and the risk appetite; receives annual assurance; approves critical risk acceptances.
CEO	Accountable for implementation; allocates resources; approves high-risk exceptions; acts as escalation point for S1 incidents.
CISO/Security Officer	Maintains the policy pack; leads risk assessment and incident response; coordinates audits and access reviews; monitors compliance; reports to CEO and Board.
Operations Manager	Owns service availability, backup and restoration, change management, hosting and vendor operations.
System Administrator	Operates servers, database, accounts and backups; implements approved changes; preserves logs; does not approve own changes or financial transactions.
Department Heads	Ensure staff are trained and comply; approve access requests for their teams; report incidents promptly.
Internal Audit	Independently reviews controls and evidence; has read-only access to systems and logs; reports to the Board/Audit Committee.
All users	Comply with this pack; protect credentials and data; report suspected incidents; complete required training.

Role	Responsibilities
Third parties	Meet contractual security obligations under AF-POL-06 and report incidents without delay.

6. Policy framework

6.1 The framework has three levels:

- **Level 1 — Policies:** this pack, approved by the CEO/Board.
- **Level 2 — Standards and procedures:** technical hardening baselines, operating procedures, incident playbooks, backup runbooks and access-review procedures.
- **Level 3 — Records:** logs, approvals, training records, test results, risk register entries and audit evidence.

6.2 The subordinate policies are AF-POL-02 to AF-POL-12. Each policy states its owner and review date. Supporting procedures must not weaken a policy requirement.

6.3 The CISO/Security Officer maintains a controlled index (AF-POL-00) and ensures only current versions are published.

7. Compliance with Ethiopian law and regulation

7.1 Anchor Financials complies with the Personal Data Protection Proclamation No. 1321/2024, the Computer Crime Proclamation No. 958/2016, applicable NBE directives, cooperative/SACCO law and INSA requirements.

7.2 The organization cooperates with INSA, NBE, law enforcement and competent authorities within legal limits. Regulatory notifications are made under AF-POL-03.

7.3 Financial and member records are retained and produced as required by AF-POL-05. Data is not transferred outside Ethiopia except with lawful basis, appropriate safeguards and management approval.

7.4 No certification is claimed by this policy. Audit evidence is maintained so that INSA and NBE can verify controls directly.

8. Exceptions

8.1 An exception is a documented, time-bound deviation from a policy requirement.

8.2 Requests must state the requirement, reason, scope, compensating controls, risk rating, owner and expiry date, and must be approved by the CISO/Security Officer.

8.3 Exceptions rated High or Critical also require CEO approval; Critical exceptions also require Board approval. Exceptions affecting audit, financial reporting or member data require consultation with Internal Audit and Compliance.

8.4 Exceptions are valid for no more than 12 months, are recorded in the exception register and are reviewed quarterly. Expired exceptions must be closed or re-approved.

8.5 A policy exception does not suspend legal or regulatory obligations.

9. Review and monitoring

9.1 The CISO/Security Officer monitors compliance through access reviews, log reviews, vulnerability management, incident trends, backup tests and audit findings.

9.2 This policy and the pack are reviewed annually by 11 November, and after a major incident, major change, new regulation or significant audit finding.

9.3 Management review considers risk status, incidents, audit results, training completion, exceptions and resource needs. Results are reported to the Board.

10. Disciplinary consequences

10.1 Violations may result in corrective action, withdrawal of access, formal warning, disciplinary proceedings up to termination, recovery of losses, or referral to law enforcement.

10.2 Consequences apply proportionately to employees, contractors and third parties, and are applied consistently with Human Resources policy and Ethiopian labour law.

10.3 Suspected fraud, data theft, sabotage or unauthorized access is referred immediately to the CEO and Internal Audit, and may be reported to police.

11. Related policies

AF-POL-00 (Index), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-05 (Data Retention), AF-POL-07 (Acceptable Use), AF-POL-08 (Training), AF-POL-09 (Risk), AF-POL-11 (Logging).

02 — Access Control and Authentication Policy

Document control	
Policy ID	AF-POL-02
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All users, administrators, contractors and third parties with an Anchor CBS account or privileged access.

1. Purpose

1.1 To ensure that access to Anchor CBS and its supporting infrastructure is authorized, unique, role-appropriate and reviewed, and that authentication resists compromise.

1.2 To enforce least privilege and segregation of duties over financial and administrative functions.

2. Principles

2.1 Access is granted on least privilege and need to know, for a defined business purpose and period.

2.2 Every user has a unique account. Shared, generic or group accounts are prohibited, except documented service accounts owned by a named administrator.

2.3 Access rights follow the role, not the person. Role changes require a new request and approval.

2.4 Privileged access is limited, logged, reviewed more frequently and never used for routine business transactions.

2.5 Authentication uses at least a password; ADMIN and MANAGER accounts also require SMS OTP MFA.

3. Role-based access control

3.1 Anchor CBS uses six roles. Permissions are assigned to roles and roles to users; direct per-user permission grants are prohibited except through an approved exception.

Role	Permitted functions	Prohibited functions
ADMIN	User and role administration, system configuration, branches, products, backups, health checks, audit verification.	Posting or approving financial transactions, approving loans or write-offs, altering audit records.
MANAGER	Branch oversight, approvals within delegated limits, reports, review of teller and credit activity.	User/role administration, system configuration, altering audit records.

Role	Permitted functions	Prohibited functions
TELLER	Member servicing, deposits, withdrawals, savings and share transactions, receipts, day-end cash reconciliation.	Loan approval, write-offs, GL configuration, user administration, compliance policy changes.
CREDIT_OFFICER	Loan origination, appraisal, scoring, document capture, collection follow-up.	Loan disbursement or final approval, posting to GL, user administration.
ACCOUNTANT	General ledger, journals, reconciliations, financial reports, product accounting.	User administration, loan approval, altering audit records.
AUDITOR	Read-only access to transactions, reports, configurations and audit logs.	Any create, update, delete, approval or posting action.

3.2 ADMIN accounts must not be used for business transactions. Where an administrator also performs a business role, a separate business account is issued.

3.3 The API enforces role permissions server-side. Front-end hiding of menus is not a control.

4. Segregation of duties

4.1 The following duties must be separated and performed by different users:

Activity	Originator	Approver / Checker
Loan origination and appraisal	CREDIT_OFFICER	MANAGER or delegated loan committee
Loan disbursement	CREDIT_OFFICER / TELLER	MANAGER
Write-off, restructuring, waiver	CREDIT_OFFICER	MANAGER and, above limit, CEO/Board
Journal entry	ACCOUNTANT	MANAGER or second ACCOUNTANT
User creation and role change	System Administrator	CISO/Security Officer or MANAGER
Production deployment	Developer	System Administrator / Operations Manager
Backup and restore	System Administrator	Operations Manager (verification)

4.2 A user must never approve their own transaction, change or access request. Maker-checker applies to all financial approvals.

4.3 Where staffing does not allow full separation, compensating controls (dual review, exception reporting, audit sampling) must be approved by the CISO/Security Officer and recorded as a risk under AF-POL-09.

5. Account provisioning and deprovisioning

5.1 **Request.** The line manager submits an access request stating the user, role, branch, business justification and end date (for temporary access).

5.2 **Approval.** The department head approves; the CISO/Security Officer approves privileged and ADMIN/MANAGER roles.

5.3 **Creation.** The System Administrator creates a unique account, assigns only the approved role and records the request ID. The user signs the acceptable-use acknowledgement (AF-POL-07).

5.4 **Credentials.** Initial passwords are delivered through a secure channel and must be changed at first login. Passwords and OTPs are never sent to personal email or stored in plaintext.

5.5 **Changes.** Role or branch changes require a new approved request. Old access is removed at the same time new access is granted.

5.6 **Termination.** Access is disabled immediately on notification of dismissal, resignation or abandonment, and before the person leaves the premises. Line managers must notify IT at least one business day before a planned departure.

5.7 **Contractors and third parties.** Accounts are named, time-bound, sponsored by an Anchor Financials manager and disabled at contract end. Vendor support access is supervised and logged.

5.8 **Dormancy.** Accounts unused for 60 days are disabled; ADMIN and MANAGER accounts unused for 30 days are disabled. Re-enablement requires approval.

5.9 **Leavers.** The System Administrator records the disablement date, returns or transfers data, and confirms removal in the leaver checklist.

6. Password policy

6.1 Passwords must be at least 12 characters and may be up to 64 characters.

6.2 Passwords must contain at least three of: uppercase letters, lowercase letters, numbers and symbols. They must not contain the username, the person's name, "Anchor", "CBS", or common dictionary patterns.

6.3 The last five passwords may not be reused.

6.4 Standard passwords are rotated every 180 days; ADMIN, MANAGER and service-account passwords every 90 days. Passwords are changed immediately on suspected compromise or after a privileged account is recovered.

6.5 Passwords are stored using bcrypt hashing. Plaintext or reversible storage is prohibited.

6.6 Users must not share passwords, write them on paper, store them in spreadsheets or send them by email or SMS. An approved password manager may be used for privileged credentials.

6.7 Service accounts use randomly generated passwords of at least 32 characters, are documented with an owner and purpose, and are rotated at least annually and on staff change.

6.8 Five consecutive failed logins lock the account for 15 minutes. Repeated lockouts are reviewed by the CISO/Security Officer as a possible attack.

7. Multi-factor authentication

7.1 SMS OTP MFA is mandatory for all ADMIN and MANAGER accounts. It is required for remote administrative access and for privileged actions designated by the CISO/Security Officer.

7.2 OTPs are six digits, valid for five minutes, limited to five verification attempts and subject to resend throttling. OTP values are never logged or displayed to support staff.

7.3 The enrolled phone number must be verified in person or by an approved identity check before activation. Changes to the MFA number require identity verification and CISO/Security Officer approval.

7.4 If the SMS gateway is unavailable, a break-glass procedure applies: the CISO/Security Officer authorizes access, an alternate verification channel is used, the session is logged, and the credential is rotated

afterwards.

7.5 Lost devices, SIM changes and suspected OTP interception are treated as incidents under AF-POL-03.

7.6 MFA is not a substitute for least privilege. It is an additional layer.

8. Session management

8.1 Sessions time out after 30 minutes of inactivity. JWT access tokens have a maximum lifetime of 30 minutes.

8.2 Users must log out when leaving a workstation. Screens lock automatically after 10 minutes.

8.3 Sensitive actions (user/role changes, approval above limit, backup restore, configuration change) require re-authentication.

8.4 An ADMIN may have only one active administrative session. Concurrent sessions from unusual locations are blocked or reviewed.

8.5 Sessions are invalidated on logout, password change, role change, account disablement and suspected compromise.

9. Privileged access

9.1 Privileged access includes ADMIN accounts, database superuser or migration accounts, server root/sudo, backup administration and access to secrets.

9.2 Privileged accounts are named, not shared. Generic root logins are disabled; administrators use named accounts with sudo.

9.3 Direct database access is limited to approved maintenance. The runtime application uses a least-privilege database account; migrations use a separate account.

9.4 Privileged activity is logged and reviewed monthly by the CISO/Security Officer. Audit records of privileged actions are retained under AF-POL-11.

9.5 Break-glass credentials, if used, are stored sealed in an approved safe or password manager, access is recorded, and the credential is rotated after each use.

10. Remote access

10.1 Remote access to production is permitted only through an approved VPN or secure gateway with MFA.

10.2 Remote administrative access requires a managed or approved secured device with full-disk encryption, endpoint protection and current patches.

10.3 Public or shared computers, internet cafés and personal devices without approval may not be used to access production.

10.4 Remote sessions are logged. Split tunnelling and personal cloud storage are prohibited.

11. Access reviews

11.1 The CISO/Security Officer conducts a full access review quarterly. Privileged and ADMIN/MANAGER accounts are reviewed monthly.

11.2 Reviews compare the actual account list and role assignments with approved requests and current HR status.

11.3 Department heads confirm that each user still requires access. Unconfirmed or excessive access is removed within five business days.

11.4 Review results, removals and approvals are recorded and retained for seven years as audit evidence.

11.5 Access is also reviewed after a reorganization, merger, major system change or security incident.

12. Logging of access changes

12.1 All account creation, modification, disablement, role changes, password resets, MFA resets and failed login attempts are written to the audit trail.

12.2 Access logs record the actor, target user, change made, source IP, timestamp (UTC) and outcome.

12.3 Audit trail records are append-only and hash-chained. No user, including ADMIN, may edit or delete them.

13. Exceptions and review

13.1 Exceptions follow AF-POL-01 section 8 and are recorded with compensating controls.

13.2 This policy is reviewed annually, and after any material change to roles, authentication or the audit trail.

14. Related policies

AF-POL-01 (Information Security), AF-POL-03 (Incident Response), AF-POL-06 (Vendors), AF-POL-07 (Acceptable Use), AF-POL-08 (Training), AF-POL-10 (Change Management), AF-POL-11 (Logging).

03 — Incident Response Plan

Document control	
Policy ID	AF-POL-03
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All staff, contractors and third parties who detect, report or respond to a security incident affecting Anchor CBS.

1. Purpose

1.1 To provide a consistent, timely and documented response to security incidents so that harm to members, Anchor Financials and the Anchor CBS platform is contained and regulatory obligations are met.

1.2 To preserve evidence and support learning through post-incident review.

2. Scope and definitions

2.1 An **event** is an observed occurrence. An **incident** is an event that actually or potentially compromises confidentiality, integrity or availability, or breaches policy or law.

2.2 Incidents include unauthorized access, credential compromise, malware/ransomware, data breach, fraud, denial of service, audit-trail tampering, lost devices, vendor breaches and significant control failures.

2.3 This plan covers Anchor CBS and supporting infrastructure. It is activated alongside AF-POL-04 when availability is affected.

3. Severity classification

Severity	Definition and examples	Initial response	Containment target	Escalation
S1 — Critical	Confirmed breach of member/financial data; ransomware; core CBS unavailable over 2 hours; fraud above ETB [threshold]; audit trail compromised; privileged account takeover with evidence of misuse.	Acknowledge within 15 minutes.	4 hours	CEO within 1 hour; Board within 4 hours; NBE/INSA/legal as required.
S2 — High	Targeted intrusion contained before data access; MFA bypass; ADMIN compromise without confirmed misuse; outage 1–2 hours; fraud	Acknowledge within 30 minutes.	8 hours	CEO within 4 hours; regulators if reportable.

Severity	Definition and examples	Initial response	Containment target	Escalation
	below threshold; multiple member accounts affected.			
S3 — Medium	Single account compromise; contained malware; policy violation; degraded service; suspected data exposure limited to staff.	Acknowledge within 4 hours.	24 hours	Operations Manager and CISO same day.
S4 — Low / near miss	Phishing email reported and not clicked; failed intrusion attempt; minor misconfiguration without data impact; lost unencrypted non-sensitive item.	Acknowledge within 1 business day.	5 business days	CISO; trend reporting monthly.

3.1 Severity may be raised as facts emerge. Only the Incident Commander or CEO may lower a severity, and the reason is recorded.

3.2 Suspected fraud is assessed jointly with Internal Audit and Compliance. Suspected crime is referred to police under AF-POL-01 and legal advice.

4. Roles

Role	Responsibility
Incident Commander (CISO/Security Officer)	Declares severity, directs response, approves containment actions, owns the incident record and communications.
Deputy Incident Commander	Acts if the Commander is unavailable; usually the Operations Manager.
Technical Lead (System Administrator)	Investigates, contains, eradicates and recovers systems; preserves logs.
Communications Lead	Prepares internal and external statements; coordinates with CEO/legal.
Legal and Compliance Lead	Assesses legal, NBE and data protection duties; manages regulator and law enforcement contact.
Human Resources	Supports staff-related incidents and disciplinary process.
Business Representative	Represents affected SACCO operations and approves service restoration priorities.
Internal Audit	Observes, preserves independence, and may review evidence; does not direct operations.
All staff	Report suspected incidents immediately; do not attempt independent investigation or conceal mistakes.

5. Detection and reporting

5.1 Incidents may be detected through audit-trail alerts, monitoring, failed-login and MFA alerts, backup failures, user reports, member complaints, vendor notifications, NBE/INSA contact or audit findings.

5.2 Any person who suspects an incident must report it immediately to the CISO/Security Officer at [Phone] / [Email], or to the service desk at [Phone] / [Email]. If unavailable, report to the Operations Manager at [Phone] / [Email].

5.3 Reports must state what was observed, when, which systems or members may be affected, and any action already taken. Staff must not delete evidence or test the incident themselves.

5.4 A report is logged with a unique incident ID, even if later found to be a false alarm.

6. Response lifecycle

6.1 **Preparation.** Maintain contact lists, playbooks, forensic tools, backup access and training. Test the plan annually under AF-POL-04.

6.2 **Identification.** Validate the report, determine scope and affected data, assign severity and open the incident record.

6.3 **Containment.** Apply short-term controls: disable accounts, revoke tokens, block IPs, isolate hosts, change credentials, restrict access, or take affected services offline. Preserve evidence before rebuilding.

6.4 **Eradication.** Remove malware, close the vulnerability or misconfiguration, patch, and confirm that the attacker no longer has access.

6.5 **Recovery.** Restore from verified backups or rebuild, validate data integrity and audit-trail continuity, monitor closely, and obtain business approval before returning to service.

6.6 **Closure.** Confirm that actions are complete, notifications made, evidence stored and the incident record approved by the Incident Commander.

7. Notification

7.1 The Incident Commander, with the CEO and Legal/Compliance, decides on notifications. No external statement is made without CEO approval unless law requires immediate disclosure.

Recipient	When	Owner	Target
CEO and Board	S1 immediately; S2 within 4 hours; S3 in the daily report.	Incident Commander	As per severity table
NBE	Material operational, financial or cyber incidents, or as required by NBE directives.	CEO / Compliance	Within 24 hours of confirmation, or earlier if directed
INSA	Cyber incidents and crimes within INSA reporting expectations; support audit follow-up.	CISO/Security Officer	Within 24 hours of confirmation, or as advised
Police	Suspected fraud, theft, unauthorized access or sabotage.	CEO / Legal	Promptly after legal advice
Affected members	Where there is a high risk to their rights or financial interests.	CEO / Communications	Without undue delay, in clear language
Data protection authority	Personal data breach requiring notification under Proclamation No. 1321/2024.	Legal / CISO	Within the statutory period; where none is fixed, within 72 hours of confirmation
Vendors and insurers	Where their systems, cover or obligations are affected.	Operations Manager	Within contractual notice period

7.2 Notifications must be accurate, documented and approved. The incident record notes who was notified, when, by what channel and what was said.

7.3 If the SMS gateway is unavailable, notification uses phone trees and secure email; this is tested annually.

8. Evidence preservation

8.1 Evidence includes audit-trail records, application and system logs, database records, network logs, configuration, memory or disk images, SMS gateway logs, emails and screenshots.

8.2 Preserve evidence before containment actions that could destroy it. Do not power off a compromised host unless instructed by the Incident Commander or forensic adviser.

8.3 Export audit-trail evidence with hash verification. Record the SHA-256 hash, collector, time, source and storage location.

8.4 Maintain a chain-of-custody log for every item. Store evidence in a restricted, encrypted location with access limited to the Incident Commander and Internal Audit.

8.5 Evidence is retained for seven years under AF-POL-05, or longer under legal hold.

9. Post-incident review

9.1 A post-incident review is held within 5 business days for S1/S2 and 10 business days for S3. S4 incidents are reviewed monthly in aggregate.

9.2 The review establishes root cause, timeline, impact, effectiveness of response, control gaps and corrective actions with owners and due dates.

9.3 The report is approved by the Incident Commander and shared with the CEO and Internal Audit. Lessons learned are incorporated into training, risk register and policy updates.

9.4 Corrective actions are tracked to closure. Internal Audit may verify completion.

10. Contacts

Role	Name	Phone	Email	Alternate
Incident Commander (CISO/Security Officer)	[Name]	[Phone]	[Email]	[Name] / [Phone]
CEO	[Name]	[Phone]	[Email]	[Name] / [Phone]
Operations Manager	[Name]	[Phone]	[Email]	[Name] / [Phone]
System Administrator	[Name]	[Phone]	[Email]	[Name] / [Phone]
Legal / Compliance	[Name]	[Phone]	[Email]	[Name] / [Phone]
Internal Audit	[Name]	[Phone]	[Email]	[Name] / [Phone]
Hosting provider support	[Contact]	[Phone]	[Email]	[Contact] / [Phone]
AfroMessage support	[Contact]	[Phone]	[Email]	[Contact] / [Phone]
NBE contact	[Name]	[Phone]	[Email]	[Name] / [Phone]
INSA contact	[Name]	[Phone]	[Email]	[Name] / [Phone]

10.1 The contact list is verified quarterly and after staff changes. It is available offline to the Incident Commander and Deputy.

11. Testing and review

11.1 A tabletop exercise is conducted annually and after major organizational change. It tests severity assignment, escalation, notification and evidence handling.

11.2 The plan is reviewed annually and after every S1/S2 incident or relevant audit finding.

12. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-04 (Business Continuity), AF-POL-05 (Retention), AF-POL-06 (Vendors), AF-POL-11 (Logging).

04 — Business Continuity and Backup Policy

Document control	
Policy ID	AF-POL-04
Version	1.0
Effective date	11 November 2026
Owner	Operations Manager
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: Anchor CBS production services, PostgreSQL database, supporting infrastructure, backups and the staff responsible for continuity.

1. Purpose

1.1 To ensure that Anchor Financials can continue critical SACCO operations and recover Anchor CBS within agreed timeframes after disruption.

1.2 To protect the confidentiality, integrity and availability of backups and to prove restore capability through testing.

2. Scope

2.1 This policy covers the web front end, Spring Boot API, PostgreSQL database, nginx proxy, Ubuntu hosts, configuration, secrets needed for recovery, and backup media at primary and off-site locations.

2.2 It applies to outages caused by hosting failure, hardware or database corruption, ransomware, power or network loss, human error, vendor failure and loss of key staff.

2.3 Incident classification, notification and evidence handling are governed by AF-POL-03.

3. Recovery objectives

Service / data	RTO	RPO	Notes
Core transaction processing (deposits, withdrawals, savings, shares, loan repayment)	4 hours	15 minutes	Continuous WAL archiving supports point-in-time recovery.
Member, KYC and loan records	4 hours	24 hours	Daily full backup plus WAL.
Authentication and access control	4 hours	24 hours	Restore with application and database.
Audit trail	4 hours	0	Append-only, hash-chained; restore and verify chain.
SMS OTP and notifications	24 hours	24 hours	Break-glass access under AF-POL-02 if AfroMessage is unavailable.

Service / data	RTO	RPO	Notes
Management and regulatory reports	8 hours	24 hours	Can be regenerated from restored data.

3.1 RTO is the maximum acceptable time to restore service. RPO is the maximum acceptable data loss measured in time.

3.2 These targets are the organization's approved baseline pending a formal high-availability design. Any change requires CEO approval and a corresponding update to AF-POL-09.

4. Backup requirements

4.1 **Daily full backup.** A full encrypted backup of the PostgreSQL database and required application configuration is taken daily outside peak hours.

4.2 **Transaction logs.** PostgreSQL write-ahead logs (WAL) are archived continuously, with a target transfer interval of no more than 15 minutes, to support point-in-time recovery.

4.3 **Configuration and code.** Infrastructure configuration, nginx configuration, deployment scripts, secrets references and application release artefacts are backed up with each release and at least weekly.

4.4 **Encryption.** Backups are encrypted at rest with AES-256 and in transit with TLS 1.3. Encryption keys are stored separately from the backups in an approved key store or sealed safe, with access limited to the Operations Manager and one designated administrator.

4.5 **Integrity.** Backup jobs produce a checksum and completion status. Failed or incomplete backups trigger an alert and are re-run the same day.

4.6 **Access.** Backup access requires two-person authorization for restore of production data. Restores are logged.

4.7 **3-2-1 rule.** At least three copies exist (production, primary backup, off-site), on two different media or systems, with one copy off-site and geographically separated from the primary site.

4.8 **Retention.** Backup copies are retained for 90 days on a rolling basis, subject to legal hold under AF-POL-05. Backup media are never used as the system of record.

4.9 **Cloud and hosting.** Where the hosting provider performs infrastructure snapshots, those snapshots supplement but do not replace Anchor Financials' own verified database backups.

5. Off-site storage

5.1 Off-site backups are stored at a location or cloud region separate from the production hosting site, with access restricted to named administrators.

5.2 Off-site media are encrypted, labelled, transported by an approved courier or secure transfer, and recorded in a backup log.

5.3 Restoration from off-site media must be possible without the production site.

5.4 The organization verifies annually that the off-site provider's physical and access controls meet AF-POL-12.

6. Restore and testing

6.1 A sample restore is performed quarterly. At least one restore per year must be a full restore into an isolated environment and must include audit-trail verification.

6.2 Each test records the backup used, start and completion time, data integrity checks, audit-chain result, issues found and responsible person.

6.3 Restore tests must demonstrate achievement of the RTO/RPO targets in section 3, or a documented remediation plan must be raised.

6.4 Failed tests are treated as an incident under AF-POL-03 where they indicate an inability to recover.

6.5 Test restores use masked or non-production data where practicable. If production data is used, the test environment is access-controlled and deleted after the test.

7. Disaster scenarios and response

Scenario	Response
Hosting provider outage	Activate the alternate region or rebuild from infrastructure configuration; notify staff and members; restore latest verified backup.
Database corruption	Stop writes, isolate the database, restore to the last known good point in time, reconcile transactions, verify audit chain.
Ransomware	Isolate affected systems, preserve evidence, do not pay, restore from offline backups, rebuild before reconnecting.
Power, network or cooling failure	Switch to provider redundancy or alternate site; monitor UPS/generator status.
SMS gateway outage	Use break-glass authentication under AF-POL-02 and alternate notification channels.
Loss of key staff	Use documented runbooks and cross-trained deputies; escalate to the Operations Manager.
Fraud or destructive insider action	Disable access, preserve evidence, restore affected records, involve Internal Audit and police.

7.1 The Incident Commander under AF-POL-03 directs the response. The Operations Manager owns technical recovery.

7.2 Manual fallback: if Anchor CBS is unavailable, branches record transactions on approved sequentially numbered manual vouchers with dual signatures. Vouchers are entered and reconciled once service is restored, and retained under AF-POL-05.

8. Responsibility matrix

Activity	Operations Manager	System Administrator	CISO/Security Officer	CEO
Approve backup schedule and retention	A	R	C	I
Run daily backups and monitor alerts	I	R	C	I
Manage encryption keys	A	R	C	I
Perform quarterly restore tests	A	R	C	I
Declare disaster and activate BCP	R	C	C	A

Activity	Operations Manager	System Administrator	CISO/Security Officer	CEO
Communicate with regulators	C	I	C	A
Annual BCP test and report	R	C	C	A

A = accountable, **R** = responsible, **C** = consulted, **I** = informed.

9. Business continuity arrangements

9.1 Critical processes are prioritized: member deposits and withdrawals, loan repayments, savings and shares, authentication, audit logging and regulatory reporting.

9.2 An alternate processing arrangement (secondary hosting region or rebuild capability) is documented and reviewed annually. It must not depend on the same single point of failure as production.

9.3 Key runbooks are available offline to the Operations Manager, System Administrator and Incident Commander.

9.4 Staff cross-training ensures at least two people can perform backup, restore and basic recovery.

9.5 Member and public communications templates are maintained by the Communications Lead under AF-POL-03.

10. Annual BCP test

10.1 A full BCP/DR test is conducted annually, involving business, technical and management representatives.

10.2 The test covers activation, roles, communications, restoration, manual fallback, reconciliation and return to normal service.

10.3 A test report is produced within 15 business days, including achieved RTO/RPO, gaps and corrective actions with owners and dates.

10.4 Results are reported to the CEO and Board. The policy and plans are updated based on the results.

11. Records and review

11.1 Backup logs, restore test reports, BCP test reports and key-management records are retained for seven years.

11.2 This policy is reviewed annually and after a major outage, disaster, restore failure or significant change to the platform.

12. Related policies

AF-POL-01 (Information Security), AF-POL-03 (Incident Response), AF-POL-05 (Retention), AF-POL-06 (Vendors), AF-POL-10 (Change Management), AF-POL-12 (Physical).

05 — Data Retention and Deletion Policy

Document control	
Policy ID	AF-POL-05
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All Anchor Financials data in Anchor CBS, backups, exports, logs, documents and third-party services.

1. Purpose

1.1 To keep information only as long as required for business, legal, regulatory and audit purposes, and to delete it securely afterwards.

1.2 To protect personal data and to respond consistently to data subject requests and legal holds.

2. Principles

2.1 Data is collected for defined purposes, minimized, kept accurate and retained only under this schedule.

2.2 Retention periods run from the trigger event stated in the schedule, not from the date of last access.

2.3 Deletion is suspended when a legal hold, investigation, audit or dispute applies.

2.4 Retention applies equally to production data, exports, backups, archives and third-party copies under Anchor Financials' control.

2.5 Audit records are immutable and may not be deleted or altered before their retention period expires.

3. Retention schedule

Data category	Examples	Retention period	Trigger	Owner
Member and KYC records	Member profile, identification, Fayda ID, contact details, guarantors, next of kin, membership documents	5 years after membership exit	Membership exit date	Operations Manager
Financial and transaction records	Savings, shares, deposits, withdrawals, loan disbursements, repayments, GL journals, reconciliations, statements	7 years	End of the financial year in which the record was created or the account closed	Accountant / Operations Manager

Data category	Examples	Retention period	Trigger	Owner
Loan records	Applications, appraisals, collateral, guarantees, approvals, schedules, write-offs, recoveries	7 years after final settlement or write-off	Settlement or write-off date	Credit Manager
Audit trail	Authentication, access, create/update/delete, approvals, configuration and administrative actions	7 years	Date of the audit event	CISO/Security Officer
SMS and OTP logs	Delivery status, recipient number, message type, gateway response	12 months	Date sent	Operations Manager
Backup copies	Database, configuration and release backups	90 days rolling	Backup date	Operations Manager
Incident records	Incident reports, evidence, notifications, post-incident reviews	7 years	Incident closure	CISO/Security Officer
Change records	Change requests, approvals, test evidence, deployment and post-implementation reviews	7 years	Change closure	Operations Manager
BCP, DR and backup test records	Backup logs, restore tests, BCP/DR exercises	7 years	Test or backup date	Operations Manager
Risk management records	Risk register entries, assessments, treatment evidence, acceptances	7 years	Risk closure	CISO/Security Officer
Asset disposal records	Disposal logs and certificates of destruction	7 years	Disposal date	Operations Manager
Physical access and visitor records	Visitor logs, access card and key records	2 years	Date of visit or record	Operations Manager
CCTV recordings	Entrance, exit and secure-area footage	30 days	Recording date	Operations Manager
Security and access reviews	Access review results, exception register, risk acceptances	7 years	Date of review or closure	CISO/Security Officer
Training and acknowledgement records	Completion records, phishing results, policy acknowledgements	5 years	End of employment or record date	Human Resources
Vendor contracts and due diligence	Contracts, SLAs, assessments, exit plans	7 years after contract end	Contract end date	Operations Manager
Operational and application logs	Debug, performance, proxy and deployment logs (not audit trail)	12 months	Log date	System Administrator
Regulatory reports and correspondence	NBE/INSA returns, audit correspondence, statutory reports	7 years	Date of report	Compliance / CEO

3.1 Where two periods apply, the longer period applies.

3.2 Records subject to an active legal hold are retained until the hold is released in writing, even if the schedule period has expired.

4. Legal holds

4.1 A legal hold may be issued by the CEO, Legal/Compliance or Internal Audit for litigation, investigation, regulatory request, audit or dispute.

4.2 The hold notice identifies the matter, custodians, data categories, systems and start date. It is sent to the CISO/Security Officer and Operations Manager.

4.3 On receipt, automated deletion and purge jobs are suspended for the affected data. Backups containing the data are preserved beyond 90 days.

4.4 The hold is recorded in a legal-hold register. It is released only by written notice, after which normal retention resumes and deletion occurs at the next cycle.

4.5 Staff must not delete, alter or remove data subject to a hold. Doing so is a disciplinary matter and may be a criminal offence.

5. Secure deletion

5.1 Electronic records are deleted using approved methods: database deletion with verification, cryptographic erasure of encrypted volumes, or secure wipe consistent with NIST SP 800-88.

5.2 Paper records are cross-cut shredded or destroyed by an approved destruction vendor, with a certificate of destruction.

5.3 Deletion is performed by an authorized administrator, verified by a second person for financial, member or audit data, and recorded in a deletion log (date, category, volume, method, approver). Audit records are exported and hash-verified before any approved purge.

5.4 Backups expire automatically at 90 days through the backup lifecycle. Individual records are not selectively edited out of backups; expiry and key destruction handle backup copies.

5.5 Decommissioned disks, servers, laptops and mobile devices are sanitized before disposal or reuse. Certificates of destruction are retained for seven years.

5.6 Deletion must not destroy records needed for an audit, investigation or legal hold.

6. Masking and redaction

6.1 Personal and sensitive fields are masked by default in screens, reports and exports where full values are not required. This includes phone numbers, Fayda ID, email addresses and account numbers.

6.2 Audit logs and SMS logs must not store passwords, OTPs, JWT tokens, API keys or full identification numbers. Sensitive fields are redacted at capture.

6.3 Unmasking requires a role permission and business justification. Unmasking actions are logged.

6.4 Test and development environments use synthetic or masked data. Production data is not copied to developer machines.

6.5 Exports containing personal data are approved by the data owner, encrypted, shared through an approved channel and deleted when no longer needed.

7. Data subject requests

7.1 Requests for access, correction, deletion, restriction or objection are logged and routed to the CISO/Security Officer and Legal/Compliance.

7.2 Identity is verified before any data is disclosed or changed. Requests from third parties require lawful authority.

7.3 Requests are answered within 30 days or the period required by the Personal Data Protection Proclamation No. 1321/2024, whichever is shorter. Extensions are documented.

7.4 Deletion requests are assessed against retention obligations. Where retention is required by NBE, tax, audit or legal hold, the request is refused in part with reasons, and the data is deleted when the obligation ends.

7.5 Requests, decisions and responses are retained for seven years as evidence of compliance.

8. Storage locations

Data	Primary location	Copies / archive	Protection
Production database	Encrypted PostgreSQL at the contracted hosting provider	Encrypted daily backups off-site	TLS in transit, access control, audit logging
Audit trail	Production PostgreSQL, append-only hash-chained table	Encrypted backup and audit exports	Restricted read access, integrity verification
Backups	Primary backup storage and geographically separate off-site location	90-day rolling	AES-256 encryption, separate key custody
SMS logs	Production database and AfroMessage gateway	Gateway records per vendor contract	Masked numbers in UI, 12-month retention
Paper records	Locked registry at Anchor Financials offices	Off-site archive if approved	Access log, clean-desk rules
Exports and reports	Restricted shared repository	Encrypted removable media only with approval	Named access, deletion after purpose

8.1 Data must not be stored on personal devices, personal email, unapproved cloud services or removable media. See AF-POL-07.

8.2 Cross-border storage or transfer requires a lawful basis, a data processing agreement, a risk assessment and CEO approval.

9. Roles and monitoring

9.1 The CISO/Security Officer owns this policy and the retention schedule. Data owners are accountable for their categories.

9.2 The Operations Manager operates backup expiry and storage lifecycle. The System Administrator runs approved purge jobs and reports results.

9.3 Purge jobs run monthly. Results, exceptions and holds are reported quarterly to the CISO/Security Officer and annually to the Board.

10. Review

10.1 This policy is reviewed annually, and when laws, NBE directives or audit requirements change.

10.2 Retention periods may be extended but not shortened without CEO approval, legal advice and an updated risk assessment.

11. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Backup), AF-POL-06 (Vendors), AF-POL-07 (Acceptable Use), AF-POL-11 (Logging).

06 — Vendor and Third-Party Policy

Document control	
Policy ID	AF-POL-06
Version	1.0
Effective date	11 November 2026
Owner	Operations Manager
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All vendors, suppliers, contractors and service providers that access, process, store or support Anchor Financials data or Anchor CBS.

1. Purpose

1.1 To ensure third parties meet Anchor Financials' security, privacy and continuity requirements before engagement and throughout the contract.

1.2 To manage the risks of data disclosure, service failure, concentration, subcontracting and insecure exit.

2. Scope and criticality

2.1 This policy covers the hosting provider, AfroMessage SMS gateway, software and support suppliers, backup and off-site storage providers, IT contractors, auditors and any provider receiving personal or financial data.

2.2 Vendors are classified as:

Tier	Definition	Examples	Due diligence	Review
Critical	Processes or stores member/financial data, or outage would stop core operations.	Hosting provider, AfroMessage, database support.	Full assessment before contract and annually.	Annual plus event-driven
Important	Supports security, audit or operations but not directly member data.	Backup storage, monitoring, IT support.	Focused assessment.	Annual
Standard	Low data access and low operational impact.	Office supplies, general software.	Basic check and contract terms.	Every 2 years

2.3 A vendor register is maintained by the Operations Manager with owner, service, tier, data accessed, contract dates, review date and exit plan.

3. Due diligence

3.1 Before engagement, the vendor completes a security questionnaire covering governance, access control, encryption, logging, incident response, backup, subcontractors, data location, personnel screening and previous breaches.

3.2 Anchor Financials reviews available assurance evidence, such as independent audit reports, penetration-test summaries or certifications. Certifications are considered as evidence but are not required or claimed by Anchor Financials.

3.3 Reference checks and financial stability checks are performed for Critical vendors.

3.4 The CISO/Security Officer assesses the residual risk and records it in the risk register under AF-POL-09. Critical vendors require CEO approval.

3.5 No production data is shared before a contract and data processing terms are signed.

4. Contract and SLA requirements

4.1 Contracts must include:

- scope, services, service levels and remedies;
- confidentiality and data protection obligations consistent with Proclamation No. 1321/2024;
- permitted data use, location and cross-border transfer conditions;
- security controls and minimum standards;
- incident notification within 24 hours of discovery, with cooperation;
- audit and information rights, including access to relevant reports;
- subcontractor approval and flow-down of obligations;
- return and secure deletion of data at exit;
- business continuity and recovery commitments;
- liability, insurance and termination rights for material breach;
- breach notification to regulators and affected persons where the vendor is at fault.

4.2 Critical service levels include availability of at least 99.5% per month, excluding approved maintenance, and recovery within the RTO in AF-POL-04.

4.3 Contracts are reviewed by Legal/Compliance before signature. Verbal commitments are not accepted.

5. Data processing

5.1 Vendors process only the data and purposes specified in the contract. They must not use Anchor Financials data for marketing, analytics, model training or their own purposes.

5.2 Personal data is minimized, masked where possible, encrypted in transit and at rest, and stored only in approved locations.

5.3 Vendors must maintain access logs, protect credentials, screen personnel and notify Anchor Financials of any change to subcontractors or data location.

5.4 Cross-border processing requires a documented risk assessment and CEO approval. Where required, standard contractual clauses or equivalent safeguards are used.

5.5 On termination, the vendor returns all data in an agreed format and deletes remaining copies within 30 days, providing written confirmation.

6. AfroMessage SMS provider

6.1 AfroMessage is used for OTP delivery and member notifications. It is a Critical vendor because OTP availability affects administrative access.

6.2 The API key is stored server-side only, never in the browser or source repository, and is rotated at least annually and on suspected exposure.

6.3 Only the minimum necessary data is sent: phone number, message content and message type. Passwords, full account details and identification numbers are never sent by SMS.

6.4 Message content is approved by the business owner. OTP messages contain no member or transaction details.

6.5 Delivery logs are retained for 12 months under AF-POL-05 and reviewed for failures, abuse and unusual volume.

6.6 The contract must include delivery SLAs, incident notification, data location, confidentiality and deletion terms. A fallback procedure applies under AF-POL-02 and AF-POL-04 if the gateway is unavailable.

7. Hosting provider

7.1 The hosting provider supplies physical security, power, cooling, network and virtualization for production systems. Anchor Financials remains accountable for application, database and access controls.

7.2 The provider must demonstrate physical access control, CCTV, visitor management, environmental monitoring, redundancy and secure media disposal consistent with AF-POL-12.

7.3 The provider must notify Anchor Financials of security incidents, access requests by authorities, subprocessor changes and material outages without undue delay.

7.4 Anchor Financials reviews the provider's assurance reports annually and records any gaps. Where assurance is insufficient, the CISO/Security Officer may require an on-site assessment or compensating controls.

7.5 Production data must be hosted in an approved location. Backup copies must be geographically separate as required by AF-POL-04.

8. Access restrictions

8.1 Vendor access is named, approved, time-bound and limited to the minimum required. Shared vendor accounts are prohibited.

8.2 Remote vendor access requires MFA, an approved secured device, and supervision or session logging.

8.3 Vendor access to production data requires a written request, CISO/Security Officer approval and a defined support window. Access is disabled when the task ends.

8.4 Vendors must not copy production data to their own systems without approval. Any approved copy is encrypted, minimized and deleted after use.

8.5 All vendor access is logged and included in the quarterly access review under AF-POL-02.

9. Monitoring and annual review

9.1 The Operations Manager monitors SLA performance, incidents, security notifications and contract obligations.

9.2 Critical vendors are reviewed annually against the due diligence criteria, with updated assurance evidence, incident history and risk rating.

9.3 Reviews are brought forward after a vendor breach, major outage, ownership change, subcontractor change or new regulatory requirement.

9.4 Review results and actions are reported to the CISO/Security Officer and included in management review.

10. Vendor incidents

10.1 Vendors must notify Anchor Financials within 24 hours of discovering an incident affecting Anchor Financials data or services, or sooner where the contract requires.

10.2 Anchor Financials treats a vendor incident as its own incident under AF-POL-03, assesses member and regulatory impact, and coordinates containment.

10.3 The vendor must provide an incident report, root cause, affected data, remediation and evidence of closure.

10.4 Repeated or material failures may lead to service credits, remediation plans, suspension or termination.

11. Exit and transition

11.1 Every Critical vendor has a documented exit plan covering data extraction, format, deletion, transition support, timelines and costs.

11.2 Exit is triggered by contract end, material breach, insolvency, unacceptable risk or business change.

11.3 Data is returned and verified before access is removed. Deletion certificates are obtained and retained for seven years.

11.4 Transition is treated as a change under AF-POL-10 and tested to avoid service disruption.

12. Review

12.1 This policy is reviewed annually and after a vendor incident or significant regulatory change.

13. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Continuity), AF-POL-05 (Retention), AF-POL-09 (Risk), AF-POL-10 (Change), AF-POL-12 (Physical).

07 — Acceptable Use Policy

Document control	
Policy ID	AF-POL-07
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All employees, directors, contractors, interns, temporary staff and third parties who use Anchor Financials systems, devices, networks or data.

1. Purpose

1.1 To define acceptable and prohibited use of Anchor Financials information systems, so that use is professional, lawful, secure and consistent with Anchor CBS operations.

1.2 To protect members, staff and the organization from fraud, data loss, malware and reputational harm.

2. Authorized use

2.1 Access is provided for approved business purposes. Limited personal use of email and internet is permitted where it does not interfere with work, consume significant resources, breach law or create risk.

2.2 Users must follow their role permissions, approval limits and segregation-of-duties rules under AF-POL-02.

2.3 Users must complete required security awareness training and acknowledge this policy before receiving an account.

2.4 Users must keep credentials confidential, lock their workstation when unattended, and report loss, theft or suspected compromise immediately.

2.5 Users must verify the identity and authority of anyone requesting data, payments or changes, and must not bypass maker-checker controls.

3. Prohibited activities

3.1 The following are prohibited:

- sharing accounts, passwords or OTPs, or allowing another person to use a logged-in session;
- accessing data without a business need, or browsing member accounts out of curiosity;
- altering, deleting or concealing records, audit logs or evidence;
- processing transactions outside approved limits or without required approval;

- installing unauthorized software, browser extensions or utilities;
- connecting unauthorized devices, USB storage or personal media to the network;
- using personal email, personal cloud storage or messaging apps for member or financial data;
- sending phishing, spam, chain messages or offensive material;
- attempting to bypass security controls, scan or penetrate systems without written authorization;
- using systems for fraud, theft, money laundering, unauthorized lending or personal gain;
- copying, photographing or screen-recording member or financial data without approval;
- using another person's credentials or accessing their mailbox or files without authorization;
- any activity that breaches Ethiopian law, NBE directives or the Personal Data Protection Proclamation No. 1321/2024.

3.2 Suspected fraud or theft is reported under AF-POL-03 and may be referred to police.

4. Devices and network use

4.1 Only organization-owned or explicitly approved devices may access production systems. Devices must run supported software, current patches, endpoint protection and full-disk encryption.

4.2 Users must not disable antivirus, firewalls, screen locks, logging or device management controls.

4.3 Laptops and mobile devices must be locked when unattended and stored securely when travelling. Loss or theft is reported immediately.

4.4 Personal devices may access email or collaboration tools only through approved services with MFA. Personal devices may not store member or financial data.

4.5 Removable media is prohibited unless approved and encrypted by the CISO/Security Officer for a specific purpose.

4.6 Users must connect to production only through approved networks and VPN, never public Wi-Fi without protection.

4.7 Anchor CBS workstations must not be left logged in at branch counters or shared areas.

5. Email and internet

5.1 Users must exercise caution with attachments, links and unexpected requests. Payment or data requests that appear urgent must be verified by phone using a known number.

5.2 Phishing and suspicious email must be reported to [Email] and not forwarded to colleagues.

5.3 Email must not be used to send passwords, OTPs, full card or account credentials, or unencrypted bulk personal data.

5.4 Internet access is monitored and filtered. Attempts to access malicious, illegal or inappropriate sites are blocked and reviewed.

5.5 Users are responsible for the content they send and must use approved signatures and disclaimers where required.

6. Data handling

6.1 Member, KYC, financial and personnel data is classified Internal or Confidential and must be accessed only on a need-to-know basis.

6.2 Data must not be stored on personal drives, personal email, unapproved cloud services, USB sticks or local desktops.

6.3 Approved shared repositories must have named access, encryption and backup. Exports require owner approval and must be deleted when the purpose ends.

6.4 Paper records containing personal or financial data must be locked away, transported securely and shredded when no longer needed under AF-POL-05.

6.5 Screens showing member or financial data must not be visible to unauthorized persons. Privacy filters are used in public-facing areas where required.

6.6 Data must be masked or redacted in reports and screenshots where full values are unnecessary.

6.7 Data must not be taken home, copied for personal use or used for training or testing without approval and masking.

7. Clean desk and clear screen

7.1 At the end of each day, desks must be clear of documents containing personal, financial or confidential information. Such documents are locked in approved storage.

7.2 Whiteboards and notice boards must not display member or financial data.

7.3 Screens lock after 10 minutes of inactivity and users must lock manually when leaving. Printouts are collected immediately.

7.4 Keys, tokens and access cards must not be left unattended or shared.

8. Reporting

8.1 Users must report suspected incidents, phishing, malware, data loss, fraud, policy violations and control weaknesses immediately to the CISO/Security Officer at [Phone] / [Email] or the service desk at [Phone] / [Email].

8.2 Reports made in good faith are protected. Users will not be penalized for reporting their own mistake promptly.

8.3 Deliberate concealment of a breach or failure to report is itself a disciplinary matter.

9. Monitoring and privacy

9.1 Anchor Financials monitors systems, networks, email, access and activity for security, compliance, fraud prevention and operational purposes.

9.2 By using Anchor Financials systems, users consent to monitoring and logging. Monitoring is conducted in accordance with Ethiopian law and the Personal Data Protection Proclamation No. 1321/2024.

9.3 Monitoring is proportionate and access to monitoring data is restricted to authorized personnel. Personal communications are not inspected unless necessary for an investigation and authorized by the CEO or Legal.

9.4 Users must have no expectation of privacy in organization-owned systems, devices, accounts or data.

9.5 Monitoring records are handled under AF-POL-05 and AF-POL-11.

10. Consequences

10.1 Violations may result in withdrawal of access, corrective action, formal warning, disciplinary action up to termination, recovery of losses, and referral to law enforcement.

10.2 Contractors may have their contract suspended or terminated and may be removed from site.

10.3 Consequences are applied consistently with Human Resources policy and Ethiopian labour law.

11. Acknowledgement and review

11.1 All users sign an acknowledgement before account activation and annually thereafter. Acknowledgement records are kept by Human Resources for five years.

11.2 This policy is reviewed annually and after a significant incident or change in law.

12. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-05 (Retention), AF-POL-08 (Training), AF-POL-11 (Logging), AF-POL-12 (Physical).

08 — Security Awareness and Training Policy

Document control	
Policy ID	AF-POL-08
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All employees, directors, contractors, interns, temporary staff and relevant third-party users.

1. Purpose

1.1 To equip staff with the knowledge and skills to recognize threats, handle member and financial data safely, and follow Anchor Financials policies.

1.2 To build a security-aware culture that supports Anchor CBS operations and INSA/NBE expectations.

2. Objectives

2.1 Ensure every user understands their security responsibilities before receiving access.

2.2 Reduce incidents caused by phishing, weak credentials, unsafe data handling and social engineering.

2.3 Ensure developers and administrators have role-specific secure engineering and operational skills.

2.4 Provide evidence of training completion for audit and management review.

3. Training requirements

Audience	Training	Timing	Refresher
All new users	Security induction: policies, acceptable use, passwords/MFA, phishing, data handling, incident reporting, clean desk	Before account activation	Annual
All staff	Annual security awareness	Within 12 months of last training	Annual
All staff	Phishing awareness and simulated phishing	At induction	Quarterly simulations; annual formal module
TELLER, CREDIT_OFFICER, ACCOUNTANT	Fraud, maker-checker, member verification, transaction security	Before role access	Annual

Audience	Training	Timing	Refresher
MANAGER	Approval controls, incident escalation, access review duties	Before role access	Annual
ADMIN and System Administrators	Privileged access, secure configuration, logging, backup, incident response	Before privileged access	Every 6 months
Developers and engineers	Secure coding, OWASP Top 10, input validation, secrets management, secure SDLC, database migration safety	Before production access	Annual and on major technology change
Incident responders	Incident response plan, evidence handling, communications, BCP activation	Before joining the team	Annual exercise
Contractors and vendors	Confidentiality, acceptable use, incident reporting, access rules	Before access	Annual or at contract renewal
Board and senior management	Cyber risk, governance, regulatory obligations, incident oversight	On appointment	Annual briefing

3.1 Training content is updated after significant incidents, audit findings, new threats, regulatory changes or major system changes.

3.2 Training is delivered in a language and format accessible to staff, including Ethiopian working languages where needed.

4. Onboarding

4.1 Human Resources notifies the CISO/Security Officer of new starters before their start date.

4.2 The new user completes security induction, signs the acceptable-use acknowledgement (AF-POL-07) and confirms understanding before the System Administrator activates the account.

4.3 Role-specific training is completed within 30 days of role assignment. Privileged users must complete privileged training before receiving elevated access.

4.4 Line managers are responsible for ensuring their staff attend and complete training.

5. Phishing awareness

5.1 Simulated phishing exercises are conducted at least quarterly. Results are used to target additional training, not to punish individuals.

5.2 Users must report suspicious messages using the approved reporting channel. Reporting rates and click rates are tracked as awareness metrics.

5.3 Users who repeatedly fail simulations receive one-to-one coaching. Repeated failure may lead to restricted access pending completion.

5.4 Real phishing campaigns affecting the organization are communicated promptly with clear guidance.

6. Secure coding and technical training

6.1 Developers must understand secure coding for Java/Spring Boot, JavaScript front ends and PostgreSQL, including authentication, authorization, input validation, output encoding, SQL injection prevention, file upload safety and secrets management.

6.2 Developers must not introduce code that weakens authentication, audit logging, role checks or encryption without approved change and security review under AF-POL-10.

6.3 Developers receive training on the immutable audit trail and the importance of not logging passwords, OTPs, tokens or unnecessary personal data.

6.4 Technical staff receive annual updates on vulnerabilities affecting the stack (Ubuntu, nginx, Spring Boot, PostgreSQL, Java, Node.js) and on secure configuration.

6.5 Training completion is required before a developer receives production repository or deployment rights.

7. Privileged user training

7.1 ADMIN, database administrators and System Administrators complete training on privileged access, least privilege, break-glass procedures, log integrity, backup security and incident escalation.

7.2 Privileged users are briefed on the prohibition on using administrative access for financial transactions or to alter audit records.

7.3 Refresher training is required every six months and after any privileged-access incident.

8. Awareness communications

8.1 The CISO/Security Officer issues awareness communications at least monthly, covering current threats, policy reminders, incident lessons and safe practices.

8.2 Awareness content is displayed in staff areas, intranet and onboarding materials.

8.3 Staff are encouraged to report concerns and near misses without blame.

8.4 Awareness metrics are reported to management quarterly and to the Board annually.

9. Tracking and records

9.1 Attendance, completion, assessment scores and acknowledgements are recorded in the training register.

9.2 Completion is tracked by department and role. The organization targets at least 90% completion for mandatory annual training.

9.3 Non-completion is escalated to the line manager, then Human Resources. Persistent non-completion may result in suspension of access.

9.4 Training records are retained for five years under AF-POL-05 and are available to Internal Audit and INSA on request.

9.5 The CISO/Security Officer reports training status, phishing results and gaps to the CEO and Board annually.

10. Consequences

10.1 Failure to complete mandatory training may result in withdrawal of access or disciplinary action under AF-POL-01 and AF-POL-07.

10.2 Deliberate violations demonstrated during training or awareness exercises are handled under the disciplinary process, not treated as training issues.

11. Review

11.1 This policy and the training plan are reviewed annually, and after major incidents, audit findings or technology changes.

12. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-07 (Acceptable Use), AF-POL-09 (Risk), AF-POL-10 (Change), AF-POL-11 (Logging).

09 — Risk Management Policy

Document control	
Policy ID	AF-POL-09
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All Anchor Financials functions, information assets, projects, vendors and changes affecting Anchor CBS.

1. Purpose

1.1 To establish a consistent method for identifying, assessing, treating, monitoring and reporting information security risks.

1.2 To connect security risk to business objectives, audit findings, INSA requirements and management decisions.

2. Scope

2.1 This policy covers risks to the confidentiality, integrity and availability of Anchor CBS, member and financial data, supporting infrastructure, people, vendors and regulatory compliance.

2.2 It applies to routine operations, projects, new systems, third-party arrangements, changes and incidents.

3. Risk methodology

3.1 Risk is assessed as **likelihood × impact** using a 5×5 matrix. Scores range from 1 to 25.

3.2 **Likelihood** is the probability of the event occurring within 12 months, considering existing controls.

Score	Likelihood	Description
1	Rare	Exceptional circumstances; less than 5% chance.
2	Unlikely	Could occur but not expected; 5–20%.
3	Possible	Might occur at some time; 20–50%.
4	Likely	Will probably occur; 50–80%.
5	Almost certain	Expected to occur or already occurring; over 80%.

3.3 **Impact** considers financial loss, member harm, service disruption, regulatory breach, legal liability and reputational damage.

Score	Impact	Description
1	Insignificant	Minor inconvenience; no data or financial loss; contained internally.
2	Minor	Limited internal disruption; small recovery cost; no regulatory reporting.
3	Moderate	Service degradation; limited member impact; reportable internally; some regulatory attention.
4	Major	Significant outage or data exposure; financial loss; NBE/INSA notification likely; reputational harm.
5	Severe	Prolonged outage, widespread data breach, major fraud or regulatory action; threat to viability.

3.4 **Risk score bands:**

Score	Rating	Required action	Acceptance authority
1–4	Low	Accept and monitor; standard controls.	Risk owner
5–9	Medium	Treat within an agreed plan; monitor quarterly.	CISO/Security Officer
10–15	High	Treat with priority; CEO visibility; monthly monitoring.	CEO
16–25	Critical	Immediate action; restrict or stop activity; Board decision.	Board

3.5 Inherent risk is assessed before additional controls. Residual risk is assessed after controls and is the basis for acceptance.

4. Risk appetite

4.1 Anchor Financials has a **low appetite** for risks affecting member funds, member data, audit integrity and regulatory compliance.

4.2 The organization tolerates low residual risk in routine operations and accepts medium residual risk only where treatment is impractical and compensating controls exist.

4.3 High residual risk requires CEO approval with a time-bound treatment plan. Critical residual risk is not accepted without Board approval and immediate containment.

4.4 Risks that could cause widespread data breach, undetected fraud, loss of audit integrity or prolonged core service outage are never accepted without Board sign-off.

5. Risk register

5.1 The CISO/Security Officer maintains a single risk register. Each entry contains:

Field	Description
Risk ID	Unique identifier (for example R-001).
Asset / process	System, data, service or business process affected.
Risk description	Cause, event and consequence.
Threat / vulnerability	Relevant threat source and weakness.

Field	Description
Existing controls	Preventive, detective and corrective controls in place.
Likelihood / impact	Scores before additional treatment.
Inherent score	Likelihood × impact.
Treatment option	Mitigate, transfer, avoid or accept.
Treatment plan	Actions, owner and due date.
Residual likelihood / impact	Scores after treatment.
Residual score and rating	Basis for acceptance.
Risk owner	Named accountable manager.
Status	Open, in treatment, accepted, closed.
Review date	Next scheduled review.
Linkages	Related audit finding, INSA checklist row, incident or change.

5.2 The register is stored in a restricted repository. Sensitive risk details are shared on a need-to-know basis.

5.3 Risks are not closed without evidence that treatment is complete or that acceptance is approved.

6. Risk treatment

6.1 **Mitigate.** Apply controls to reduce likelihood or impact. Most security risks are treated this way.

6.2 **Transfer.** Transfer financial or contractual risk through insurance, contracts or vendor obligations. Transfer does not remove accountability.

6.3 **Avoid.** Stop the activity or do not implement the system or feature.

6.4 **Accept.** Retain the risk with documented justification, owner, expiry and monitoring. Acceptance follows the authority table in section 3.4.

6.5 Treatment plans state actions, resources, owner, due date, success criteria and residual risk target. Overdue actions are escalated.

7. Ownership and responsibilities

Role	Responsibility
Board	Sets risk appetite; approves critical risks; oversees the risk portfolio.
CEO	Accountable for risk management; approves high risks and treatment resources.
CISO/Security Officer	Maintains methodology and register; facilitates assessments; monitors treatment; reports to CEO and Board.
Risk owners	Identify, assess and treat risks in their area; update the register; provide evidence.
Operations Manager	Manages operational, continuity and vendor risks.
Internal Audit	Reviews risk process and treatment evidence independently; does not own risks.

Role	Responsibility
All staff	Identify and report risks and control weaknesses.

8. Assessment cadence

8.1 A full risk assessment is conducted annually and before major changes, new systems, new vendors or new regulatory obligations.

8.2 The risk register is reviewed quarterly by the management team. High and critical risks are reviewed monthly.

8.3 Event-driven reviews occur after an S1/S2 incident, a material audit finding, a significant outage, a data breach or a major change in law or NBE direction.

8.4 Project risk assessments are completed before go-live and recorded in the change request under AF-POL-10.

9. Linkage to audits and INSA

9.1 Audit findings from Internal Audit, external audit, NBE or INSA are entered in the risk register with an owner and due date.

9.2 Each risk may reference the relevant INSA OF/AEAD/001 checklist area and control, and the related vulnerability or audit finding.

9.3 Remediation evidence is retained and made available to auditors. Closure of an audit finding requires verification by Internal Audit or the CISO/Security Officer.

9.4 The risk register is a primary input to the annual management review and the security budget.

10. Reporting and metrics

10.1 The CISO/Security Officer reports quarterly on the risk profile, new and closed risks, overdue treatments, incidents and audit actions.

10.2 The annual report to the Board covers risk appetite, top risks, residual exposure, treatment progress and any accepted risks.

10.3 Metrics include number of high/critical risks, percentage of treatment actions on time, recurring risks and audit findings past due.

11. Review

11.1 This policy and the methodology are reviewed annually, and after major incidents or changes in the risk environment.

12. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Continuity), AF-POL-06 (Vendors), AF-POL-10 (Change), AF-POL-11 (Logging).

10 — Change Management Policy

Document control	
Policy ID	AF-POL-10
Version	1.0
Effective date	11 November 2026
Owner	Operations Manager
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: All changes to Anchor CBS production systems, code, configuration, database, infrastructure, security controls and integrations.

1. Purpose

1.1 To control changes so that they are authorized, tested, secure, traceable and reversible, and do not disrupt SACCO operations or compromise data.

1.2 To prevent unauthorized or untested modifications to production, including direct database changes.

2. Scope

2.1 This policy covers:

- application code, APIs, UI and dependencies;
- database schema, data migrations, reference data and configuration;
- nginx, TLS, DNS, firewall and server configuration;
- Ubuntu, Java, PostgreSQL and other infrastructure components;
- user roles, permissions and security settings;
- integrations with AfroMessage, hosting and monitoring services;
- emergency fixes and vendor-supplied updates.

2.2 Changes to business data made through approved application functions are transaction operations, not change requests, but remain subject to maker-checker under AF-POL-02.

3. Change types

Type	Definition	Approval	Lead time	Records
Standard	Low-risk, repeatable change following a pre-approved procedure (for example routine certificate renewal, adding a branch, approved dependency patch).	Pre-approved by Operations Manager; executed by System Administrator.	Per procedure	Change log entry

Type	Definition	Approval	Lead time	Records
Normal	Any change not classified as standard or emergency. Includes features, schema changes, access model changes and infrastructure updates.	Change Advisory Board (CAB): Operations Manager, CISO/Security Officer and business owner.	At least 5 business days before deployment	Full change record
Emergency	Urgent fix for a security incident, critical defect or service outage.	Incident Commander or Operations Manager; CISO consulted for security changes.	Immediate, retrospective approval	Emergency record within 24 hours

3.1 The change owner proposes the type. The Operations Manager confirms it. Disputed classifications are treated as Normal.

3.2 A change that affects authentication, authorization, audit logging, encryption, personal data or external exposure always requires security review, even if small.

4. Change request and approval

4.1 Every Normal change has a request containing:

- title, description, business justification and affected services;
- change type, risk rating and rollback plan;
- implementation steps, schedule and responsible persons;
- testing and UAT evidence;
- security impact assessment;
- database migration details, if any;
- communication and support arrangements.

4.2 The CAB reviews risk, testing, timing, dependencies and rollback. Approval is recorded with names and dates.

4.3 Changes are not deployed without approval. The System Administrator must verify the approval reference before deployment.

4.4 High-risk changes require CEO approval. Changes affecting member data, financial reporting or regulatory obligations also require Compliance review.

4.5 The change calendar is maintained by the Operations Manager. Changes are scheduled outside peak SACCO hours, month-end, payroll and regulatory reporting periods unless justified.

5. Testing and UAT

5.1 Changes are tested in a development environment and then in a staging environment that reflects production configuration.

5.2 Testing covers functional behavior, negative cases, role permissions, input validation, error handling and audit logging.

5.3 Security testing is performed for changes affecting authentication, access control, data handling, external interfaces or dependencies. This includes authorization checks for each affected role and verification that sensitive data is not logged.

5.4 User acceptance testing is performed by the business owner or nominated users. UAT sign-off is recorded before production deployment.

5.5 Database migrations are tested on a recent copy of production data (masked where practicable) and timed to confirm the maintenance window.

5.6 Failed tests block deployment. Exceptions require CISO/Security Officer and business owner approval with compensating controls.

6. Segregation of duties

6.1 Developers must not approve or deploy their own changes to production.

6.2 Code is peer-reviewed before merge. At least one reviewer other than the author approves.

6.3 The System Administrator or Operations Manager deploys to production. Where a developer must deploy, a second person reviews and approves the deployment, and the event is logged.

6.4 Production database changes are executed by the System Administrator or a designated database administrator, not by application developers.

6.5 Access to production secrets and deployment credentials is restricted and logged.

7. Security review

7.1 Security review is required when a change:

- modifies login, MFA, passwords, sessions, roles or permissions;
- modifies audit logging, log retention or log access;
- introduces or changes encryption, key management or certificate handling;
- processes new personal or financial data, or changes data sharing;
- adds an external interface, vendor, API or data export;
- changes infrastructure, network exposure or backup configuration;
- introduces a major dependency or framework upgrade.

7.2 The review checks least privilege, input validation, secure defaults, error handling, logging, data protection and rollback safety.

7.3 Findings are recorded and resolved before deployment, or accepted by the CISO/Security Officer with a risk entry under AF-POL-09.

8. Deployment and rollback

8.1 A rollback plan is mandatory for Normal and Emergency changes. It states triggers, steps, responsible person, data implications and estimated time.

8.2 A backup is taken before any database migration or high-risk change. The restore path is verified.

8.3 Deployment follows the approved steps. Outputs and timestamps are recorded in the change record.

8.4 Post-deployment checks confirm service health, authentication, key transactions, audit logging and error rates.

8.5 If checks fail, the rollback plan is executed. Rollback decisions are recorded and treated as an incident if service or data is affected.

8.6 Changes are not left partially applied. Database migrations use versioned, forward-only scripts; a corrective migration is prepared where rollback is unsafe.

9. Database migration control

9.1 Schema changes are applied through the approved migration tool (Flyway) using versioned scripts under source control. Manual production DDL is prohibited except in an approved emergency, and must be captured as a migration afterward.

9.2 Migration scripts are peer-reviewed for correctness, locking, performance, data loss and rollback impact.

9.3 Destructive changes (dropping columns or tables, rewriting data) require explicit approval, a backup, and a documented data-retention assessment under AF-POL-05.

9.4 The runtime application database account has only the privileges required for operation. Migration credentials are separate and restricted.

9.5 Migration results and any exceptions are recorded in the change record.

10. Emergency changes

10.1 Emergency changes may be approved verbally by the Incident Commander or Operations Manager when delay would worsen an incident.

10.2 The change is logged immediately with the reason, scope, approver and time. A full record and retrospective approval are completed within 24 hours.

10.3 A post-implementation review is completed within 5 business days. Repeated emergency changes are analyzed for root cause.

10.4 Emergency changes still require testing where practicable and a rollback plan. Security-critical changes require CISO involvement.

11. Post-implementation review

11.1 A post-implementation review is completed within 5 business days for Normal changes and all Emergency changes, and for any change that caused an incident.

11.2 The review confirms objectives met, no unintended impact, monitoring results, user feedback, rollback status and lessons learned.

11.3 Corrective actions are assigned and tracked. Significant issues are added to the risk register.

12. Records and review

12.1 Change records, approvals, test evidence, UAT sign-off, deployment logs and post-implementation reviews are retained for seven years.

12.2 The Operations Manager reports monthly on change volume, emergency changes, failures, rollbacks and overdue actions.

12.3 This policy is reviewed annually and after a major change failure or audit finding.

13. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Continuity), AF-POL-09 (Risk), AF-POL-11 (Logging).

11 — Logging and Monitoring Policy

Document control	
Policy ID	AF-POL-11
Version	1.0
Effective date	11 November 2026
Owner	CISO/Security Officer
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: Anchor CBS application, API, database, servers, network components, authentication services and administrative activity.

1. Purpose

1.1 To generate, protect and review records that detect and investigate security events, support audit and regulatory requirements, and preserve accountability for financial and administrative actions.

1.2 To ensure the audit trail is complete, accurate, time-synchronized and tamper-evident.

2. Events to be logged

Category	Events
Authentication	Successful and failed login, logout, lockout, unlock, password change/reset, MFA challenge, OTP success/failure/resend, token issuance and revocation.
Authorization	Access denied, role check failure, privilege escalation attempt, unauthorized API request.
User administration	Account creation, modification, disablement, role assignment, MFA reset, access review action.
Business activity	Member create/update, deposit, withdrawal, transfer, savings and share transaction, loan origination, approval/rejection, disbursement, repayment, write-off, journal posting.
Approvals	Maker-checker approval or rejection, override, limit exception.
Configuration	Product, branch, charge, interest, GL rule, notification template, system setting and security configuration changes.
Administrative actions	Backup, restore, scheduler run, cache clear, migration, deployment, service restart, database maintenance.
Audit integrity	Hash-chain verification result, verification failure, attempted update/delete on audit tables.
Errors and availability	Application errors, exceptions, failed jobs, health-check failures, disk/CPU/database alerts, TLS and certificate errors.
Network and infrastructure	nginx access/error logs, firewall denies, unusual outbound connections.

Category	Events
Vendor and remote access	VPN login, vendor support session start/end, break-glass use.

2.1 Events relevant to financial transactions, approvals, access and administration must be recorded in the immutable audit trail. High-volume operational logs may be stored separately.

3. Log content

3.1 Each audit event records:

- unique event ID and timestamp in UTC;
- actor user ID, username, role and branch;
- action, entity type, entity ID and outcome;
- field changed, old value and new value (redacted where sensitive);
- source IP address and user agent;
- request or correlation ID;
- hash of the previous record and hash of the current record.

3.2 Logs must be sufficient to reconstruct who did what, when, from where and with what result.

3.3 Passwords, OTPs, JWT tokens, API keys, PINs and full sensitive identifiers must never be written to logs. Sensitive fields are redacted at capture.

3.4 Log timestamps use a single time standard (UTC). Local time may be displayed but the stored value is UTC.

4. Immutable audit trail

4.1 The Anchor CBS audit trail is append-only and protected by a SHA-256 hash chain. Each record includes the hash of the preceding record, so alteration or deletion breaks the chain.

4.2 Database triggers reject UPDATE and DELETE on the audit trail and SMS log tables. Application users, including ADMIN, have no interface to modify or delete audit records.

4.3 Audit-trail integrity is verified at least daily and before any audit export. A failed verification is an S1 or S2 incident under AF-POL-03, depending on scope.

4.4 Audit exports are accompanied by the verification result and a SHA-256 hash of the export file, recorded in the chain-of-custody log.

4.5 No one may disable, bypass or weaken audit logging. Any planned maintenance affecting logging requires CISO/Security Officer approval and compensating monitoring.

5. Time synchronization

5.1 All servers, network devices and database hosts synchronize time using authenticated NTP from approved sources.

5.2 NTP drift is monitored. A drift above 5 seconds triggers an alert and correction.

5.3 Timezone configuration is documented. Application logs and audit records store UTC; business reports may display East Africa Time (EAT).

5.4 If NTP is unavailable, the system continues on local clock and the Operations Manager is notified. The event is recorded and reviewed.

6. Retention

6.1 Audit trail records are retained for seven years under AF-POL-05.

6.2 Authentication and security event logs are retained for seven years where they form part of the audit trail.

6.3 Operational, application, nginx and debug logs are retained for 12 months, unless required for an incident, legal hold or audit.

6.4 SMS logs are retained for 12 months.

6.5 Logs subject to an investigation or legal hold are preserved beyond the standard period.

6.6 Retention is enforced by automated lifecycle rules. Deletion is logged and approved; audit records cannot be deleted before expiry.

7. Access to logs

7.1 Access to audit and security logs is restricted to:

Role	Access
AUDITOR	Read-only, including export for audit purposes.
ADMIN	Read-only for defined operational purposes; cannot modify or delete.
MANAGER	Read-only for branch and approval activity within their authority.
CISO/Security Officer	Read, investigate, export and configure alerts.
System Administrator	Operational logs; audit-table access limited and logged.

7.2 Shared log accounts are prohibited. All access to audit data is itself logged.

7.3 Logs are stored in a restricted repository with encryption at rest and access controls. Exports are encrypted and stored in the approved evidence location.

7.4 Audit logs are not copied to personal devices or unapproved cloud services.

8. Review and monitoring

Review	Frequency	Owner
Automated alert triage	Continuous	System Administrator / CISO
Failed login and lockout review	Daily	System Administrator
Audit-trail integrity verification	Daily	System Administrator
Privileged and administrative action review	Monthly	CISO/Security Officer

Review	Frequency	Owner
Access review	Quarterly (privileged monthly)	CISO/Security Officer
Log configuration and retention check	Quarterly	CISO/Security Officer
Full log review for audit evidence	Before audit and annually	Internal Audit

8.1 Reviews record the reviewer, date, sample or period, findings and actions. "No findings" is recorded explicitly.

8.2 Anomalies are raised as incidents under AF-POL-03.

9. Alerting

9.1 Automated alerts are configured for at least:

- five consecutive failed logins or repeated lockouts;
- failed MFA attempts or OTP abuse;
- login from a new country or unusual IP for privileged accounts;
- role or permission changes, especially ADMIN/MANAGER;
- after-hours administrative activity;
- audit-trail verification failure or attempted modification;
- backup or restore failure;
- database availability, disk capacity or certificate expiry;
- unusual transaction volume, large value transactions or repeated overrides;
- malware or endpoint protection alerts;
- configuration changes to logging, TLS, firewall or authentication.

9.2 Alerts are routed to a monitored mailbox or on-call channel. Critical alerts require acknowledgement within 15 minutes.

9.3 Alert rules are reviewed quarterly to reduce false positives and cover new threats.

9.4 Alert failures or gaps are treated as control failures and reported to the CISO/Security Officer.

10. Protection of logs

10.1 Log storage is segregated from general application data where practicable, with write-only collection and restricted read access.

10.2 Logs are encrypted in transit and at rest. Backups of logs follow AF-POL-04.

10.3 Administrative access to log infrastructure requires MFA and is logged.

10.4 Logs must not be sent to third parties except under AF-POL-06, a legal requirement or an approved audit.

10.5 Tampering with, disabling or deleting logs is a disciplinary matter and may be a criminal offence.

11. Privacy and personal data

11.1 Logs may contain personal data. Collection is limited to what is necessary for security and audit.

11.2 Access to logs is need-to-know and monitored. Log data is used only for security, audit, fraud prevention, dispute resolution and legal purposes.

11.3 Data subject requests are handled under AF-POL-05, subject to legal and audit retention requirements.

11.4 Log data is masked where full values are not required, particularly phone numbers and identification numbers.

12. Review

12.1 This policy is reviewed annually, and after a logging failure, audit finding, major incident or change to the audit architecture.

13. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Continuity), AF-POL-05 (Retention), AF-POL-06 (Vendors), AF-POL-09 (Risk), AF-POL-10 (Change).

12 — Physical and Environmental Security Policy

Document control	
Policy ID	AF-POL-12
Version	1.0
Effective date	11 November 2026
Owner	Operations Manager
Approver	CEO / Board
Classification	Internal
Review date	11 November 2027

Applies to: Anchor Financials offices, server rooms, hosting facilities, devices and staff working on or off site.

1. Purpose

1.1 To prevent unauthorized physical access, damage, interference, theft or loss affecting Anchor CBS, its data and supporting equipment.

1.2 To ensure power, cooling, fire protection and environmental conditions support reliable service.

2. Scope

2.1 Anchor CBS production infrastructure is hosted at the contracted hosting provider. This policy applies to the provider's data-centre controls, any Anchor Financials server room or network closet, branch and office areas, and all devices used to access Anchor CBS.

2.2 Where a control is operated by the hosting provider, Anchor Financials verifies it through contract terms, assurance reports and periodic assessment. Accountability remains with Anchor Financials.

3. Hosting provider and data-centre controls

3.1 The hosting provider must maintain:

- controlled entry with badge, biometric or equivalent authentication;
- 24/7 monitoring and response;
- visitor authorization, escort and logging;
- CCTV coverage of entries, aisles and equipment areas;
- fire detection and suppression;
- redundant power, UPS and generator or equivalent;
- temperature, humidity and water-leak monitoring;
- secure media storage and destruction;
- protection against unauthorized cabling or equipment connection.

3.2 Anchor Financials reviews the provider's assurance evidence annually and records the result. Gaps require compensating controls or a remediation plan under AF-POL-09.

3.3 The provider must notify Anchor Financials of physical security incidents, unauthorized access attempts and planned maintenance that could affect service.

3.4 Production data must not be hosted in an unapproved location. Cross-border hosting requires approval under AF-POL-06.

4. Access authorization

4.1 Access to secure areas is limited to named personnel with a documented business need.

4.2 Access is approved by the Operations Manager and reviewed at least annually. Access is removed immediately when the need ends or employment terminates.

4.3 Access cards, keys and codes are personal, not shared, and are returned on leaving. Lost cards are deactivated immediately.

4.4 A current access list is maintained for each secure area. The list is reconciled with HR records quarterly.

4.5 Vendor technicians require a written request, approval and escort. Their access is time-limited and recorded.

5. Visitors

5.1 Visitors sign in and out at reception, provide identification, state their host and purpose, and wear a visitor badge.

5.2 Visitors are escorted in secure areas at all times. They must not connect devices, access systems or photograph equipment without approval.

5.3 Visitor logs record name, organization, host, purpose, time in/out and badge number. They are retained for two years, or longer if related to an incident.

5.4 Deliveries are received at a controlled loading area and inspected before being brought into secure areas.

6. CCTV and monitoring

6.1 CCTV covers entrances, exits, secure-area corridors and equipment rooms where lawful and proportionate.

6.2 Cameras are positioned to avoid private areas. Signage informs staff and visitors of monitoring.

6.3 Recordings are retained for 30 days, unless required for an incident or investigation, and access is restricted to authorized security and operations staff.

6.4 Recordings are disclosed only to law enforcement or under legal authority, with CEO or Legal approval.

6.5 CCTV systems are tested and maintained, and time is synchronized.

7. Power and environmental controls

7.1 Production equipment is protected by UPS with sufficient runtime for orderly shutdown or generator start, and by surge protection.

7.2 UPS and generator systems are tested at least quarterly. Test results are recorded.

7.3 Temperature, humidity and water ingress are monitored with alarms. Conditions outside approved ranges trigger a response.

7.4 Fire detection and suppression systems are maintained and inspected according to the provider's schedule and local requirements.

7.5 Cabling is protected, labelled and separated to prevent accidental damage or interception.

7.6 Maintenance activities are scheduled, authorized and recorded and must not bypass security controls without approval.

8. Secure disposal

8.1 Equipment containing data (servers, disks, laptops, phones, printers, copiers, removable media) is sanitized before disposal, reuse, repair or transfer.

8.2 Sanitization uses approved methods consistent with NIST SP 800-88: cryptographic erasure, secure overwrite or physical destruction.

8.3 Paper containing personal, financial or confidential data is cross-cut shredded or destroyed by an approved vendor, with a certificate of destruction.

8.4 Disposal is authorized by the Operations Manager and recorded in an asset disposal log. Certificates are retained for seven years.

8.5 Devices are not sold, donated or discarded with storage intact. Asset tags and data-bearing components are accounted for.

9. Laptop and device controls

9.1 Organization laptops and mobile devices use full-disk encryption, screen locks, endpoint protection and current patches.

9.2 Devices are registered to a named user and recorded in the asset register. Unregistered devices may not connect to the network.

9.3 Devices are stored securely when not in use. Laptops are not left visible in vehicles or public areas.

9.4 Loss or theft is reported immediately to the CISO/Security Officer and treated as an incident under AF-POL-03. Access is revoked and the device is remotely wiped where possible.

9.5 Repairs and maintenance are performed by approved providers. Data is backed up and, where practicable, removed before repair.

9.6 USB and removable media restrictions are governed by AF-POL-07.

10. Office and branch security

10.1 Secure areas are locked when unattended. Keys and access cards are controlled and logged.

10.2 Reception and branch counters are arranged so that screens and documents are not visible to members or visitors.

10.3 Cash and negotiable instruments are protected under separate finance procedures; this policy covers their information and system aspects only.

10.4 Staff must challenge unescorted strangers in secure areas and report suspicious persons or activity.

10.5 Clean-desk and clear-screen rules apply under AF-POL-07.

11. Remote work

11.1 Remote access to Anchor CBS production is permitted only for approved roles and with organization-managed devices.

11.2 Remote access uses the approved VPN or secure gateway with MFA under AF-POL-02.

11.3 Staff must use a private, lockable space, avoid public Wi-Fi without protection, and prevent shoulder surfing or overhearing of member data.

11.4 Member and financial data must not be printed, stored locally or removed from approved systems when working remotely.

11.5 Remote workers must report loss, theft, intrusion or suspected compromise immediately.

12. Incident reporting and review

12.1 Physical security incidents (unauthorized access, theft, damage, power failure, environmental alarm, lost device) are reported immediately to the Operations Manager and CISO/Security Officer, and handled under AF-POL-03.

12.2 The site is preserved for investigation where appropriate.

12.3 This policy is reviewed annually, and after a physical incident, relocation, new hosting arrangement or audit finding. A site assessment is conducted at least annually.

13. Related policies

AF-POL-01 (Information Security), AF-POL-02 (Access Control), AF-POL-03 (Incident Response), AF-POL-04 (Continuity), AF-POL-05 (Retention), AF-POL-06 (Vendors), AF-POL-07 (Acceptable Use), AF-POL-11 (Logging).